Access Controls Policy

Company: RS Solutions Inc. (operating Bargain Bay and RS Solutions)

Address: 1135 Squires Beach Rd, Pickering, ON L1W 3T9, Canada

Policy owner: Owner / Director (Service@rssolutions.ca)

Version: 1.0

Effective date: November 2, 2026

Review cycle: at least once every 12 months, and after any security incident or change of roles

Related policy: Information Security Policy

1. Purpose and scope

This policy defines who may access company systems and data, how access is granted, checked and removed, and how sign-in is protected. It covers all people (owner, employees, contractors, drivers, sales staff, dispatch coordinators, accountants, marketplace vendors and their team members) and all systems that hold company data: the Bargain Bay and RS Solutions web applications and their administrative screens, the production database, the master inventory tracker (Google Sheets), the hosting, source-code, email, banking-data (Plaid), advertising and payment provider accounts.

2. Principles

- **Least privilege.** Each person gets only the access their job needs, and nothing more.
- **Individual accounts.** Every person signs in as themselves. Shared logins are not used for administrative systems, so every action can be traced to a person.
- **Need to know for money.** The line between roles is the customer's sale versus the business's books: staff can run a sale and its delivery; cost, profit, payroll, banking, financial reports and system configuration are administrator-only.
- **Enforced on the server.** Permissions are checked by the server on every request. Hiding a menu item is never treated as a permission.
- **Fail safe.** If a permission cannot be determined, access is refused.

3. Roles

Role	What it can reach	What it cannot reach
Administrator (owner)	Everything, including cost and profit, payroll, banking connections, financial reports, coupons and pricing settings, granting and revoking all other access	—
Sales / staff	Quotes, invoices, orders board, dispatch, customer records, vendor drop-off intake	Cost and profit figures, payroll, books, banking connections, pricing and access settings
Dispatch coordinator	The dispatch board, run sheets, drivers' stops, proof of delivery	Every other administrative screen
Accountant	Financial dashboard, profit and loss, the records pack and expense records (read and categorise)	Orders, inventory, pricing, payroll, dispatch, granting access, connecting or disconnecting bank and accounting links
Driver	Their own stops and the driver app	Anything outside driver functions
Employee (clock only)	Their own clock-in and clock-out	Everything else
Marketplace vendor — owner, manager, listings, fulfilment, viewer	Only that vendor's own listings, orders, messages and statements, according to the team role (only the vendor owner sees money, bank details and team management)	Any other vendor's data; any customer contact details
Customer / member	Their own account, orders and (for approved members) wholesale prices	All administrative functions

The access matrix above is maintained in the application code and is the single source of truth. A new screen or API route must name the role that may use it before it is released.

4. Granting access

1. Access is requested by the person's manager or by the person, and **approved by the owner**. Nobody can grant themselves a role.
2. The owner grants the role in the application (staff, dispatch, accountant, driver, employee) or, for the owner's own administrator list, in the protected hosting configuration. Grants are made by email address and take effect when that person signs in with that address.
3. Vendor accounts are approved by company staff after identity and business-registration checks. Only the vendor owner can invite or change their own team members.
4. Access is granted at the lowest role that lets the person do their work. Administrator access is limited to the owner.
5. Each grant records who gave it and when.

5. Authentication

- **Passwords** are stored only as salted bcrypt hashes. Passwords are never emailed, logged or shown. Password reset invalidates existing sessions.

- **Sessions** use signed tokens held in `httpOnly` cookies, so scripts in the browser cannot read them. A session expires after a fixed period and can be invalidated at any time by raising the account's token version, which signs the person out everywhere.
- **Single sign-on.** Sign-in with Google or Microsoft is accepted only when the provider confirms the email address is verified. Work or school Microsoft accounts are refused because their email claim is controlled by a third-party administrator.
- **Drivers** sign in with a one-time code sent by text message to the mobile number the company has on file, or a one-time link on first use. Codes expire after 15 minutes, are limited to five wrong attempts and five sends per hour, are stored hashed, and the response is identical for unknown numbers so the driver list cannot be discovered.
- **Multi-factor authentication.** Marketplace vendor owner accounts must enrol in time-based one-time-password (TOTP) two-factor sign-in; codes work once, wrong attempts cause an increasing lock-out, and recovery codes are single-use. Changing bank details or team members requires a fresh code. The owner must enable multi-factor authentication on every third-party administrator account that supports it (hosting, database, source code, Google, Plaid, email, domain registrar, advertising and payment accounts).
- **Brute-force and abuse controls.** Account-creation and ordering endpoints are rate-limited, one-time codes (driver and vendor two-factor) have attempt limits and lock-outs, and the owner can block abusive identifiers.

6. Privileged access and secrets

- Administrator rights are limited to the owner. Administrator access cannot be revoked from itself in a way that would lock the business out of its own system.
- Access to production secrets (database credentials, Plaid keys, API keys, encryption keys) is limited to the owner. Secrets live in the hosting provider's protected configuration, never in source code, email or chat, and are rotated when a person with access leaves or exposure is suspected.
- Bank and Plaid connections can be created, changed and removed only by an administrator. Vendor bank account numbers are encrypted, can be shown only as the last four digits, and can be changed only by the vendor owner with step-up authentication, subject to a cooling-off period during which the old account remains in use.
- Direct access to the production database is limited to the owner and used only for maintenance and recovery.

7. Reviewing access

- The owner reviews the complete list of people with access, and their roles, **at least every quarter** and whenever someone joins, changes role or leaves. The review covers application roles, drivers, accountants, vendor teams, and each third-party service account.
- Unused accounts and roles are removed. Dormant elevated access is treated as a finding, not an oversight.
- Access changes and sensitive actions (invoices, refunds, order changes, pricing markdowns, coupons, access grants) are recorded in an append-only audit log showing who did what and when, and the owner uses it in the review.

8. Removing access

- **Leavers and role changes.** Access is removed or reduced **on the day** the person leaves or changes role. Application roles are revoked in two clicks without a deployment; revoked grants are kept as history, not deleted, so the record of who had access and when remains.
- Revocation takes effect immediately on the instance that performs it and within about thirty seconds everywhere else. Sessions are invalidated by raising the account's token version.
- On removal the owner also: removes the person from third-party accounts, rotates any shared secret they knew, disconnects their devices, and recovers company property.
- Driver sign-in links and codes for an old phone number are cancelled when a driver's number changes; a driver who leaves is switched off rather than deleted so their history stays intact.
- Accountant access is time-bound by practice: it is granted for a season or engagement and revoked at its end.

9. Third-party and remote access

Vendors, accountants and contractors receive only role-based access described above, never owner credentials. Providers that process company data (Plaid, Vercel, Neon, Google, Stripe, Resend, Twilio and advertising platforms) are accessed through individual accounts with multi-factor authentication. Programmatic access uses scoped API keys held as protected configuration.

10. Devices and physical access

Devices used for administration must have a screen lock, disk encryption and current updates. Shared warehouse computers are signed out after use; driver and staff phones that are lost are reported immediately so the person's sessions and sign-in are revoked. The warehouse and office are locked outside business hours, and keys or access codes are held only by people who need them.

11. Exceptions and enforcement

Any exception to this policy needs the owner's written approval, a stated reason and an end date. Breaching this policy, including sharing a login, may result in loss of access and other disciplinary action. Suspected misuse is handled under the incident response process in the Information Security Policy.